

ĐẠI HỌC QUỐC GIA TP.HCM

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN



**ĐỒ ÁN MÔN HỌC
AN TOÀN MẠNG**

CHÍNH SÁCH BẢO MẬT HOÀN CHỈNH

BLUE TEAM

Giảng viên hướng dẫn – TS. Lê Kim Hùng

Sinh viên thực hiện:

23520552 – Phan Cảnh Đăng Huân

23520479 – Lê Đình Hiếu

Mục lục

1. MỤC ĐÍCH.....	3
2. PHẠM VI ÁP DỤNG	3
2.1. Phạm vi hạ tầng mạng.....	3
2.2. Đối tượng áp dụng	3
3. QUY ĐỊNH & BIỆN PHÁP BẢO VỆ.....	4
3.1. Quy định an ninh chung	4
3.2. Kiểm soát luồng mạng & tường lửa	4
3.3. Tăng cường bảo mật hệ thống.....	5
3.4. Bảo mật ứng dụng & giám sát.....	5
3.5. Sao lưu & khôi phục	6
3.6 An ninh thiết bị đầu cuối.....	6
3.7 Chiến lược bảo vệ dữ liệu toàn diện	7
4. BẢNG QUY TẮC TƯỜNG LỬA	8
4.1 Vùng WAN (Inbound từ Internet)	8
4.2 Vùng DMZ (192.168.20.0/24).....	8
4.3 Vùng LAN 10 - Web Services (192.168.10.0/24)	9
4.4 Vùng LAN 20 - Data/File Services (192.168.30.0/24)	10
4.5 Vùng LAN 30 - Employee Network (192.168.40.0/24)	11
4.6 Vùng LAN 40 - Management (192.168.50.0/24)	12
5. BÁO CÁO SỰ CỐ & TUÂN THỦ	12
5.1. Quy trình ứng phó sự cố	12
5.2. Kỷ luật & tuân thủ	12
6. TÀI LIỆU THAM KHẢO.....	13

1. MỤC ĐÍCH

Mục đích của chính sách này là thiết lập các quy định bắt buộc về quản lý, vận hành và bảo mật hạ tầng mạng ảo hóa. Chính sách nhằm đảm bảo 3 mục tiêu an toàn thông tin (CIA Triad) trước các mối đe dọa thực tế:

1. **Tính bí mật:** Ngăn chặn truy cập trái phép vào dữ liệu nhạy cảm tại File Server (LAN20) và thông tin quản trị.
2. **Tính toàn vẹn:** Đảm bảo mã nguồn Web Server, Logs hệ thống (Wazuh) và cấu hình mạng không bị thay đổi trái phép (FIM).
3. **Tính sẵn sàng:** Đảm bảo các dịch vụ Web, File và hệ thống giám sát luôn hoạt động ổn định, giảm thiểu tác động của tấn công DoS và sự cố kỹ thuật.

2. PHẠM VI ÁP DỤNG

2.1. Phạm vi hạ tầng mạng

Chính sách áp dụng cho toàn bộ các thành phần ảo hóa trên nền tảng VMware, được quản lý bởi Gateway pfSense, bao gồm các phân vùng mạng cụ thể sau:

- Vùng WAN: Địa chỉ do DHCP cấp - Kết nối Internet/Host.
- Vùng DMZ: 192.168.20.0/24 - Chứa Reverse Proxy (Nginx + ModSecurity) tiếp nhận request từ bên ngoài.
- Vùng LAN 10: 192.168.10.0/24 - Chứa Web Server Backend (WebGoat/App) được ẩn giấu.
- Vùng LAN 20: 192.168.30.0/24 - Chứa File Server (Samba) lưu trữ dữ liệu nội bộ.
- Vùng LAN 30: 192.168.40.0/24 - Mạng dành cho máy tính nhân viên.
- Vùng LAN 40: 192.168.50.0/24 - Vùng quản trị chứa Wazuh SIEM Server.

2.2. Đối tượng áp dụng

- Quản trị viên hệ thống.
- Người dùng nội bộ.
- Tất cả tài sản phần cứng, phần mềm và dịch vụ nằm trong kiến trúc mạng nêu trên.

3. QUY ĐỊNH & BIỆN PHÁP BẢO VỆ

3.1. Quy định an ninh chung

(Tham chiếu: ISO 27001:2022 - Control 5.15 & 5.17 & 8.17 & 8.2)

- **Quản lý xác thực:** Mật khẩu quản trị phải tối thiểu 12 ký tự (bao gồm chữ hoa, chữ thường, số và ký tự đặc biệt). Hệ thống sẽ tự động khóa tài khoản sau 5 lần đăng nhập sai liên tiếp.
- **Zero Trust:** Không tin tưởng bất kỳ thiết bị nào, kể cả trong mạng nội bộ. Mọi kết nối liên vùng đều phải đi qua tường lửa để kiểm tra.
- **Nguyên tắc quyền tối thiểu:** Chỉ mở các port và dịch vụ thực sự cần thiết cho vận hành. Cấm toàn bộ các traffic không được định nghĩa.
- **Quyền hạn người dùng cuối:** Người dùng tại vùng LAN30 chỉ được cấp quyền người dùng tiêu chuẩn. Nghiêm cấm cấp quyền quản trị (root hoặc Administrator) cho máy nhân viên để ngăn chặn cài đặt phần mềm trái phép.
- **Đồng bộ thời gian:** Tất cả máy chủ và thiết bị mạng phải đồng bộ thời gian (NTP) với Gateway pfSense để đảm bảo tính nhất quán của log phục vụ điều tra.

3.2. Kiểm soát luồng mạng & tường lửa

(Tham chiếu: ISO 27001:2022 - Control 8.20 & 8.22)

Hệ thống tường lửa pfSense và IPS Suricata đóng vai trò chốt chặn chính:

1. Chống trình sát

- CHẶN toàn bộ gói tin ICMP Echo Request (Ping) từ vùng WAN vào hệ thống.
- Ẩn thông tin phiên bản phần mềm (Server Tokens/Banner) trên các cổng dịch vụ công khai.

2. Phát hiện & Ngăn chặn Xâm nhập (IDS/IPS):

- Kích hoạt Suricata trên Interface WAN và các LAN quan trọng.
- Sử dụng bộ luật ET Open Rules để phát hiện dấu hiệu tấn công (Port Scan, Exploit).
- Cấu hình chế độ Block Offenders: Tự động chặn IP nguồn có hành vi tấn công trong thời gian quy định.

3. Phân vùng mạng:

- DMZ Isolation: DMZ chỉ được phép forward traffic HTTP/HTTPS vào Web Server (LAN10). CẤM DMZ kết nối ngược vào các mạng nội bộ khác (LAN20, 30, 40).
- Web Isolation: Web Server (LAN10) bị chặn kết nối trực tiếp ra Internet (trừ Update/DNS) và cấm kết nối sang mạng người dùng (LAN30).
- User Restrictions: Mạng nhân viên (LAN30) bị chặn truy cập trang quản trị Firewall và vùng Server (LAN10, LAN40).

3.3. Tăng cường bảo mật hệ thống

(Tham chiếu: ISO 27001:2022 - Control 8.8 & 8.19)

Áp dụng cho tất cả máy chủ Ubuntu (Web, Proxy, File, Wazuh):

- **SSH Security:** Cấu hình PermitRootLogin no và DebianBanner no để ẩn thông tin OS.
- **Web Hardening:** Nginx cấu hình server_tokens off để ẩn phiên bản.
- **Host Firewall:** Kích hoạt tường lửa cục bộ (UFW/IPTables) trên từng máy chủ như lớp bảo vệ thứ hai.
- **Quản lý phần mềm:** Các phần mềm phải luôn được cập nhật phiên bản ổn định và mới nhất. Tuyệt đối không sử dụng các phần mềm đã ngưng hỗ trợ hoặc các phiên bản chứa lỗ hổng bảo mật đã được công bố.

3.4. Bảo mật ứng dụng & giám sát

(Tham chiếu: ISO 27001:2022 - Control 8.15 & 8.26 & 8.7 & 8.24)

1. Web Application Firewall (WAF):

- Hệ thống Reverse Proxy tại DMZ tích hợp ModSecurity với bộ luật OWASP CRS.
- Hoạt động ở chế độ Blocking: Chặn ngay lập tức các payload tấn công SQL Injection, XSS, Path Traversal.

2. Giám sát an ninh tập trung (SIEM - Wazuh):

- Agent: Tất cả máy chủ phải cài đặt Wazuh Agent và ở trạng thái Active.
- File Integrity Monitoring (FIM): Kích hoạt giám sát thời gian thực các thư mục nhạy cảm (/etc/, /var/www/, /usr/bin/) để phát hiện rootkit hoặc thay đổi trái phép.

- Log Collection: Thu thập tập trung log Nginx, System log, Auth log về Wazuh Server (LAN40).

3. Chống mã độc (Anti-Malware):

- Triển khai ClamAV trên File Server (LAN20) để quét virus định kỳ cho dữ liệu người dùng tải lên.

4. Bảo mật File Server:

- Dữ liệu lưu trữ trên File Server (LAN20) bắt buộc phải được mã hóa sử dụng thuật toán tiêu chuẩn để đảm bảo tính bảo mật ngay cả khi ổ cứng vật lý bị đánh cắp.
- Hệ thống chỉ cho phép lưu trữ các định dạng tệp phục vụ công việc (như .docx, .xlsx, .pdf, .png, .jpg, ...).
- Cấu hình chặn việc tải lên và lưu trữ các tệp tin có khả năng thực thi mã độc (như .exe, .bat, .sh, .vbs, .php, ...) trên thư mục chia sẻ.

3.5. Sao lưu & khôi phục

(Tham chiếu: ISO 27001:2022 - Control 8.13)

- **Đối tượng:** Dữ liệu quan trọng tại File Server (/srv/share) và cấu hình pfSense.
- **Tần suất:** Thực hiện sao lưu tự động (Cronjob) tối thiểu 1 lần/ngày vào khung giờ thấp điểm (23:00).
- **Lưu trữ:** Bản sao lưu phải được nén, lưu trữ cục bộ (xoay vòng 7 ngày) và khuyến nghị đồng bộ ra thiết bị lưu trữ ngoài/cloud.

3.6 An ninh thiết bị đầu cuối

(Tham chiếu: ISO 27001:2022 - Control 5.10 & 5.15 & 7.10 & 8.1 & 8.2)

Mục tiêu: Ngăn chặn mã độc xâm nhập qua con đường vật lý và hành vi người dùng bất cẩn và hạn chế quyền hạn để tránh cài đặt phần mềm trái phép.

Quy định:

- **Kiểm soát thiết bị lưu trữ ngoài (Removeable Media / USB):** Nghiêm cấm kết nối các thiết bị lưu trữ ngoài (USB, ổ cứng di động, thẻ nhớ) chưa được kiểm duyệt vào các máy tính thuộc mạng nội bộ (đặc biệt là LAN 40 và LAN 30). Nếu bắt buộc phải sử dụng USB để sao chép dữ liệu, thiết bị phải được quét virus trên máy cách ly trước khi cắm vào hệ thống.

- **An toàn duyệt Web & Email:** Người dùng trong vùng LAN 30 không được phép truy cập vào các đường dẫn (URL) lạ, không rõ nguồn gốc được gửi qua Email. Không được phép tải xuống và thực thi các tệp tin đính kèm (như .exe, .bat, .vbs, .macro office) từ các Email không tin cậy. Mọi hành vi đáng ngờ phải báo cáo ngay cho Blue Team.
- **Quản lý quyền hạn:** Tất cả tài khoản cấp cho nhân viên để làm việc hằng ngày tại vùng LAN30 phải là tài khoản thường. Nghiêm cấm cấp quyền (root, sudo hoặc Local Administrator) cho người dùng. Mỗi máy chỉ tồn tại duy nhất một tài khoản quản trị cục bộ do bộ phận IT giữ mật khẩu. Tài khoản này chỉ được sử dụng để hỗ trợ kỹ thuật (Troubleshoot). Người dùng không được phép tự ý cài đặt phần mềm. Việc cài đặt phải được thực hiện bởi quản trị viên hệ thống.

3.7 Chiến lược bảo vệ dữ liệu toàn diện

(Tham chiếu: ISO 27001:2022 - Control 8.24 & 8.12 & 8.10)

Data-in-Transit

Quy định: Mọi luồng trao đổi dữ liệu qua mạng nội bộ hoặc Internet đều phải được mã hóa đầu cuối.

Thực thi: File Server (Samba) bắt buộc sử dụng giao thức SMBv3 với chế độ mã hóa. Các hành vi quản trị phải sử dụng SSH thay vì Telnet.

Data-at-Rest:

Quy định: Dữ liệu nhạy cảm lưu trên đĩa cứng phải được bảo vệ khỏi truy cập vật lý hoặc truy cập trái phép từ hệ điều hành.

Thực thi:

Kiểm soát truy cập (ACLs): Sử dụng quyền hạn hệ thống tệp tin (Linux File Permissions chmod/chown), đảm bảo chỉ user sở hữu mới đọc được file.

Bảo vệ vật lý ảo hóa: File đĩa ảo (.vmdk) của máy chủ chứa dữ liệu được lưu trữ trên vùng Storage an toàn của hệ thống ảo hóa, được bảo vệ bởi mật khẩu quản trị viên.

Data-in-Use:

Quy định: Dữ liệu khi được xử lý trên bộ nhớ (RAM) hoặc hiển thị phải được bảo vệ.

Thực thi:

Người dùng phải khóa màn hình khi rời khỏi vị trí để tránh lộ thông tin đang hiển thị.

Các phiên làm việc kết nối đến File Server phải tự động ngắt (Timeout) nếu không hoạt động để xóa dữ liệu đệm (Cache) liên quan.

4. BẢNG QUY TẮC TƯỜNG LỬA

4.1 Vùng WAN (Inbound từ Internet)

Mục tiêu: Bảo vệ vùng biên, chỉ cho phép truy cập dịch vụ Web đã được công khai.

Luồng dữ liệu	Nguồn	Đích	Giao thức/Port	Hành động	Mục đích
Anti-Reconnaissance	Any (Internet)	WAN Address	ICMP (Ping)	BLOCK	Ngăn chặn kẻ tấn công dò quét sự tồn tại của máy chủ.
Public Web Access	Any (Internet)	Host Proxy (192.168.20.10)	TCP 80, 443	ALLOW	(NAT) Cho phép người dùng truy cập Web qua Reverse Proxy.
Default Deny	Any	Any	All Traffic	BLOCK	Chặn tất cả các truy cập trái phép khác (Implicit Deny).

4.2 Vùng DMZ (192.168.20.0/24)

Mục tiêu: Chuyển tiếp request vào Web Server và ngăn chặn tấn công vào mạng nội bộ.

Luồng dữ liệu	Nguồn	Đích	Giao thức/Port	Hành động	Mục đích
Web Forwarding	Host_Proxy (192.168.20.10)	Host_Web (192.168.10.10)	TCP 8080, 9090, 80	ALLOW	Chuyển tiếp traffic sạch từ Proxy vào Web App Backend.
SIEM Logging	DMZ Net	Host_Wazuh (192.168.50.10)	TCP 1514, 1515	ALLOW	Gửi log giám sát về máy chủ Wazuh.
Infrastructure	DMZ Net	pfSense Gateway	UDP 53 (DNS), 123 (NTP)	ALLOW	Phân giải tên miền và đồng bộ thời gian.
System Update	Host_Proxy	Internet (!RFC1918)	TCP 80, 443	ALLOW	Cập nhật hệ điều hành và cơ sở dữ liệu WAF.
DMZ Isolation	DMZ Net	RFC1918_Networks (LAN10, 20, 30, 40)	All Traffic	BLOCK	Ngăn chặn Proxy bị chiếm quyền tấn công sâu vào nội bộ.

4.3 Vùng LAN 10 - Web Services (192.168.10.0/24)

Mục tiêu: Vận hành ứng dụng Web và bảo vệ dữ liệu backend.

Lưu lượng dữ liệu	Nguồn	Đích	Giao thức/Port	Hành động	Mục đích
Backend Connect	Host_Web (192.168.10.10)	Host_File_D B (192.168.30.10)	TCP 445 (SMB) / 3306 (SQL)	ALLOW	Web Server kết nối lưu trữ dữ liệu hoặc Backup.
SIEM Logging	LAN10 Net	Host_Wazuh (192.168.50.10)	TCP 1514, 1515	ALLOW	Gửi log giám sát về Wazuh.
Infrastructure	LAN10 Net	pfSense Gateway	UDP 53, 123	ALLOW	DNS và NTP.
System Update	Host_Web	Internet (!RFC1918)	TCP 80, 443	ALLOW	Cập nhật bản vá bảo mật cho Web Server.
Server Isolation	LAN10 Net	RFC1918 Networks (LAN 30, 40)	All Traffic	BLOCK	Ngăn chặn Web Server tấn công sang máy nhân viên hoặc Admin.

4.4 Vùng LAN 20 - Data/File Services (192.168.30.0/24)

Mục tiêu: Lưu trữ dữ liệu an toàn.

Luồng dữ liệu	Nguồn	Đích	Giao thức/Port	Hành động	Mục đích (Purpose)
SIEM Logging	LAN20 Net	Host_Wazu h (192.168.50.10)	TCP 1514, 1515	ALLOW	Gửi log giám sát.
Infrastructure	LAN20 Net	pfSense Gateway	UDP 53, 123	ALLOW	DNS và NTP.
Antivirus Update	Host File DB	Internet (!RFC1918)	TCP 80, 443	ALLOW	Cập nhật cơ sở dữ liệu ClamAV.
Data Isolation	LAN20 Net	RFC1918_Networks	All Traffic	BLOCK	Cô lập vùng dữ liệu, không cho kết nối ngược ra ngoài.

4.5 Vùng LAN 30 - Employee Network (192.168.40.0/24)

Mục tiêu: Cho phép nhân viên làm việc nhưng hạn chế quyền truy cập hệ thống.

Luồng dữ liệu	Nguồn	Đích	Giao thức/Port	Hành động	Mục đích
Block Firewall	LAN30 Net	pfSense Gateway	TCP 80, 443, 22	BLOCK	Anti-Tamper: Cấm nhân viên truy cập trang đăng nhập Router/Firewall.
File Access	LAN30 Net	Host_File_DB (192.168.30.10)	TCP 445 (SMB)	ALLOW	Nhân viên truy cập tài liệu chia sẻ.
Internet Access	LAN30 Net	Internet (!RFC1918)	All Traffic	ALLOW	Truy cập Internet phục vụ công việc.
SIEM Logging	LAN30 Net	Host_Wazu h	TCP 1514, 1515	ALLOW	Gửi log máy trạm về trung tâm.
User Isolation	LAN30 Net	RFC1918_Networks (LAN10, 40)	All Traffic	BLOCK	Ngăn chặn nhân viên dò quét Server Web hoặc vùng Quản trị.

4.6 Vùng LAN 40 - Management (192.168.50.0/24)

Mục tiêu: Vùng dành riêng cho quản trị viên và hệ thống giám sát.

Luồng dữ liệu	Nguồn	Đích	Giao thức/Port	Hành động	Mục đích
Admin Access	LAN40 Net	pfSense Gateway	TCP 443, 22	ALLOW	Quản trị viên cấu hình Tường lửa.
Server Mgmt	LAN40 Net	RFC1918_Networks (All LANs)	TCP 22 (SSH), 3389 (RDP)	ALLOW	Quản trị viên truy cập sửa lỗi các máy chủ.
Threat Intel	Host_Wazuh	Internet (!RFC1918)	TCP 443	ALLOW	Wazuh cập nhật dữ liệu các mối đe dọa mới.
Default Deny	Any	Any	All Traffic	BLOCK	Chặn các luồng không xác định.

5. BÁO CÁO SỰ CỐ & TUÂN THỦ

5.1. Quy trình ứng phó sự cố

(Tham chiếu: ISO 27001:2022 - Control 5.24)

Khi hệ thống giám sát (Wazuh/Suricata) phát hiện dấu hiệu tấn công:

1. Phát hiện: SIEM gửi cảnh báo về hành vi quét cổng, đăng nhập thất bại nhiều lần hoặc tấn công Web.
2. Ngăn chặn:
 - Suricata tự động chặn IP nguồn tấn công.
 - Nếu thất bại, quản trị viên thực hiện chặn thủ công trên pfSense hoặc ngắt kết nối máy chủ bị nhiễm.
3. Điều tra: Phân tích log trên Wazuh Dashboard để xác định nguyên nhân và phạm vi ảnh hưởng.
4. Khôi phục: Khôi phục dịch vụ từ bản backup sạch gần nhất.

5.2. Kỷ luật & tuân thủ

- Hệ thống sẽ được kiểm tra định kỳ để đảm bảo các Rules Firewall và cấu hình Wazuh/Suricata hoạt động đúng thiết kế.
- Mọi hành vi cố ý tắt Firewall, tắt Wazuh Agent, hoặc tự ý mở port (Port Forwarding) không qua phê duyệt sẽ bị xử lý kỷ luật.

6. TÀI LIỆU THAM KHẢO

- [1] ISO/IEC 27001:2022 – *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.
<https://www.iso27001security.com/html/27002>
- [2] SANS Institute – *Information Security Policy Templates*.
<https://www.sans.org/information-security-policy/>
- [3] CIS Benchmarks – *CIS Ubuntu Linux 22.04 LTS Benchmark v1.0.0*.
<https://www.cisecurity.org/cis-benchmarks/>
- [4] Wazuh Documentation – *Wazuh SIEM Capabilities & Ruleset*.
<https://documentation.wazuh.com/>
- [5] OWASP Top 10 – *OWASP Top 10:2021*. <https://owasp.org/www-project-top-ten/>